

FREE GOVERNANCE GUIDE · V1.1 · REVISED OCTOBER 2026

Safe AI Use Guide

Six chapters for community banks and credit unions. Written against SR 26-2 (the April 2026 model risk guidance that superseded SR 11-7), the Interagency TPRM Guidance, ECOA / Reg B, and the AIEOG AI Lexicon (US Treasury, FBIIC, FSSCC, February 2026).

-
- 01 The never-paste list
 - 02 Private cloud vs. public model
 - 03 Model risk discipline for generative AI
 - 04 Vendor evaluation scoring
 - 05 Shadow AI discovery
 - 06 Review readiness
-

The never-paste list.

Six categories of data that must never go into a public large language model, and the reason behind each.

STANDING RULE

A public LLM is a third party. Anything typed into its prompt leaves your security perimeter. For a category not listed here, apply the same test: would you email this to an unknown vendor? If not, do not paste it.

DATA CATEGORY	COMMON EXAMPLES	BASIS
Member / customer PII	Names, SSNs, account numbers, dates of birth, addresses, phone numbers, email addresses	GLBA (Title V) safeguards and privacy requirements limit disclosure of nonpublic personal information. Pasting it into a public LLM is an uncontrolled third-party disclosure.
Loan application data	Income, employment history, credit scores, debt schedules, collateral values	ECOA / Reg B, FCRA, and fair lending obligations attach to this data. A tool that informs credit decisions is a model; manage it with the model risk discipline in SR 26-2.
Non-public supervisory information	CAMELS ratings, MRAs / MRIs, examination reports, supervisory letters	Confidential supervisory information belongs to the agency, and agency rules restrict its disclosure (e.g., FRB 12 C.F.R. Part 261; OCC 12 C.F.R. Part 4; FDIC 12 C.F.R. Part 309; NCUA 12 C.F.R. Part 792).
BSA / AML records	SAR narratives, CTR details, OFAC screening results, beneficial ownership records	SAR confidentiality (31 U.S.C. § 5318(g)) prohibits disclosing a SAR or information that would reveal one. Penalties apply.
Internal audit & legal	Draft audit findings, attorney-client communications, litigation-hold materials	Disclosure to a third party can waive privilege. Public LLM terms generally do not preserve attorney-client or work-product protection.
Vendor contracts & pricing	Core processor agreements, fintech contracts, negotiated rate schedules	Most contracts carry confidentiality clauses. Disclosure to a public LLM may breach them.

PRACTICAL STAFF TEST

Before pasting, ask: does this contain a real person's information, a real account's data, or anything I received under an expectation of confidentiality? If yes to any, stop. Use only synthetic or fully anonymized data for AI-assisted drafting.

Basis: Gramm-Leach-Bliley Act, Title V; ECOA / Regulation B (12 C.F.R. Part 1002); BSA SAR confidentiality (31 U.S.C. § 5318(g)); agency confidential supervisory information rules as listed above.

Private cloud vs. public model.

Five questions every staff member runs before entering data into any AI tool. Stop at the first answer that sets the tier.

Not every use needs private infrastructure. These questions set the minimum deployment tier from data sensitivity, regulatory exposure, and how the output will be used.

Q1

Does the task require any data from the never-paste list (Chapter 1)?

YES → Private inference only: approved private cloud or on-premises deployment. Public models prohibited.
NO → Q2.

Q2

Will the output make or support a credit, compliance, or hiring decision?

YES → Private inference required. Treat the output as model output: validate it, document it, and have it independently reviewed. SR 26-2 leaves generative AI outside its formal scope, so record the controls you apply. NO → Q3.

Q3

Do the vendor's terms permit training on submitted data?

YES → Public model not permitted for internal work. Evaluate an enterprise tier with a training opt-out, or private deployment. NO, opt-out confirmed in writing → Q4.

Q4

Is the data classified Internal Only?

YES → Enterprise-licensed tier required (e.g., Microsoft 365 Copilot or Google Workspace Gemini with data-loss controls). Consumer and free tiers prohibited. NO, the data is public or synthetic → Q5.

Q5

Is the tool on the institution's approved AI inventory?

YES, approved tool and public data only → Public model permitted. Record the use in the AI use case inventory. NO → Do not use. Submit it for vendor evaluation (Chapter 4) first.

Basis: SR 26-2, Revised Guidance on Model Risk Management (FRB / OCC / FDIC, April 2026; supersedes SR 11-7). AIEOG AI Lexicon (US Treasury / FBIIC / FSSCC, February 2026): "AI use case inventory".

Model risk discipline for generative AI.

SR 26-2 replaced SR 11-7 in April 2026. Here is how its disciplines map to the AI tools your staff actually use.

WHERE THE GUIDANCE STANDS

SR 26-2 is non-binding, and generative and agentic AI sit outside its formal scope while the agencies gather input. That is a gap, not a pass. Per GAO-25-107197 (May 2025), there is no comprehensive AI-specific banking regulation; oversight runs through existing frameworks: model risk guidance, the Interagency TPRM Guidance for vendors, and ECOA / Reg B for credit. The AIEOG AI Lexicon supplies the shared vocabulary.

MODEL RISK DISCIPLINE	GENERATIVE AI EQUIVALENT	ACTION FOR YOUR FRAMEWORK
Development, implementation, and use	Selecting and deploying an AI system	Document the intended use, data inputs, and business process before deployment. Assign an owner.
Validation	Output accuracy and hallucination testing	Set a challenge process. For high-stakes outputs (credit, compliance), a person reviews AI-generated content before it is used.
Ongoing monitoring	Output quality drift	Track output quality over time. Re-evaluate when the vendor updates the underlying model.
Model inventory	AI use case inventory	Keep a living register of every AI tool in use: data inputs, business purpose, risk tier, owner. The AIEOG AI Lexicon calls this the "AI use case inventory".
Third-party model risk	Vendor and API-based AI services	Apply the Interagency TPRM Guidance to every AI vendor: security attestation (e.g., SOC 2 Type II), data retention terms, right to audit.
Sensitivity and stress testing	Adversarial prompt and red-team testing	Before production use in lending or compliance, test for prompt injection, jailbreaks, and data leakage.
Independent review	AI governance committee	A cross-functional committee (IT, Compliance, Risk, Operations, Audit) on a quarterly cadence, reporting to the board.

Sources: SR 26-2, Revised Guidance on Model Risk Management (FRB / OCC / FDIC, April 17, 2026; supersedes SR 11-7, 2011). GAO-25-107197, US Government Accountability Office (May 2025). AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC (February 2026).

Vendor evaluation scoring.

Five questions, scored 0–3 each, for a maximum of 15. Passing score: 9. Below 9, do not deploy without a remediation plan and board notification.

15 Approved	12–14 Approved with conditions	9–11 Conditional: remediation required	< 9 Do not deploy
-----------------------	--	--	--------------------------------

Q1 · Data handling and retention

Does the vendor contractually commit to no training on your data, with a documented retention period inside your TPRM policy?

3 Written opt-out; data deleted within 30 days	2 Opt-out available; retention unclear	1 No opt-out; data retained for model improvement	0 Terms silent on training or retention
--	--	---	---

Q2 · Security certifications

SOC 2 Type II, ISO 27001, or FedRAMP, current within 12 months?

3 SOC 2 Type II current; penetration test available	2 SOC 2 Type I or ISO 27001 only	1 Certification in progress	0 No third-party certification
---	--	---------------------------------------	--

Q3 · Right to audit and subprocessors

Is there a right-to-audit clause, with material subprocessors disclosed and held to equivalent controls?

3 Audit right confirmed; subprocessors listed and auditable	2 Questionnaire only; subprocessors disclosed	1 No audit right; partial disclosure	0 Contract silent; not disclosed
---	---	--	--

Q4 · Concentration risk

What share of your AI-dependent workflows would this vendor carry?

3 Under 25%; redundancy plan exists	2 25–50%; backup vendor identified	1 Over 50%; no fallback plan	0 Single point of failure
---	--	--	-------------------------------------

Q5 · Explainability and human review

For outputs used in decisions, does the system explain its reasoning, and is human review required before action?

3 Explanations available; review required by design	2 Explanations on request; review optional	1 Limited explainability; review not enforced	0 Black-box output; no review step
---	--	---	--

Basis: Interagency Guidance on Third-Party Relationships: Risk Management (OCC / FRB / FDIC, June 2023). AIEOG AI Lexicon terms: human-in-the-loop, explainability, third-party AI risk (February 2026).

Shadow AI discovery.

A five-phase method to find the AI tools staff already use and bring them inside governance without killing adoption.

WHY THIS MATTERS NOW

Gartner Peer Community data cited by Jack Henry (2025) found 55% of financial institutions had no AI governance framework and 57% reported team-level skill gaps. The usual cause: staff adopted tools before governance existed. A punitive search drives shadow AI further underground. This method surfaces tools through trust, not surveillance.

Phase 1	Anonymous discovery survey. Ask all staff: "What AI tools do you use in your work, including personal tools?" Guarantee that management will not review individual responses. Without that safety, people underreport. Output: raw inventory of tools in use, by department.	Week 1
Phase 2	DNS / proxy log review. Pull 30 days of outbound DNS or proxy logs. Search for known AI domains (openai.com, claude.ai, gemini.google.com, perplexity.ai, and newer tools). Compare against the approved list. Output: tools in use but not on the approved inventory.	Weeks 1–2
Phase 3	Department interviews. Twenty minutes with each department head: "Walk me through a week of work. Where do you use AI?" Start with productivity, not compliance. Output: use-case map per department; high-risk workflows identified.	Weeks 2–3
Phase 4	Risk classification. Run each tool through the Chapter 2 questions. Tools whose data requires private inference but that run on public models are first-priority remediation. Output: risk-tiered shadow AI register.	Week 3
Phase 5	Governance integration. Score each tool with Chapter 4. At 9 or above and within approved data tiers, add it to the AI use case inventory. Below 9, tell users, offer an approved alternative, and document the decision. Output: updated inventory; closure notice to affected staff.	Week 4

Data: "Getting Started in AI," Jack Henry & Associates (2025), citing Gartner Peer Community research. Figures as published in 2025.

Review readiness.

What to have ready for an audit, risk review, or exam conversation, in the vocabulary of the AIEOG AI Lexicon.

THE SHARED VOCABULARY

The AIEOG AI Lexicon (US Treasury, FBIIC, FSSCC, February 2026) gives the financial sector a shared AI vocabulary. It is non-binding. Using its terms in your inventory, policy, and reports makes the program easier for any reviewer to follow.

WORKING DEFINITIONS, ALIGNED TO THE AIEOG AI LEXICON

AI use case inventory

A living register of the AI systems the institution uses or plans to use, with business purpose, data inputs, risk tier, validation status, and owner for each.

AI governance

The policies, procedures, and controls used to manage AI from deployment to retirement, including oversight, accountability, and audit trail.

Hallucination

AI output that is incorrect or fabricated but presented with apparent confidence. Any high-stakes output used in decisions needs a plan for catching it.

Human-in-the-loop (HITL)

A design in which a person reviews and approves AI output before it is acted on. For regulated decisions (credit, compliance), treat it as the baseline.

Explainability

How well the reasoning behind an output can be stated in plain language. Under ECOA / Reg B, an adverse action notice needs specific reasons; "the model said so" is not one.

Third-party AI risk

Risk from AI systems built, run, or hosted by a vendor. Manage it under the Interagency TPRM Guidance: due diligence, contract protections, monitoring, concentration analysis.

Model risk **SR 26-2 / AIEOG cross-reference**

The potential for harm from decisions based on incorrect or misused model output. For generative AI it includes hallucinated output, prompt injection, and behavior changes after the vendor updates the model.

AI bias

Systematic unfairness in AI output from training data, design, or deployment context. Fair lending review asks whether AI-assisted underwriting produces disparate impact under ECOA / Reg B.

The review-ready packet.

Keep a current version and a dated history of each item, so the program shows it has been operating, not assembled for the review.

- AI use case inventory: current, dated, owner assigned
- AI governance policy: board-approved, reviewed annually
- Vendor evaluation record for each AI tool (Chapter 4 scorecard or equivalent)
- Model risk mapping for AI tools (Chapter 3 framework or equivalent)
- Shadow AI discovery log: at least one cycle completed
- Human-review documentation for any AI-assisted lending or compliance workflow
- Hallucination incident log, even if empty; the log shows the control exists
- Board presentation on AI governance within the past 12 months
- Staff training records: AI acceptable-use training by role
- Adverse action notice review: AI-generated reasoning is never cited verbatim

BOARD REPORTING

We recommend a quarterly AI governance summary to the full board: (1) active AI tools by department and risk tier; (2) vendor evaluation changes; (3) shadow AI found and remediated; (4) staff training completion; (5) any incidents involving AI output. Five slides, twenty minutes.

Sources: AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC (February 2026). GAO-25-107197, US Government Accountability Office (May 2025): no comprehensive AI-specific banking regulation; model risk guidance (SR 26-2), the Interagency TPRM Guidance, and ECOA / Reg B apply. Cornerstone Advisors, AI Playbook for Banks and Credit Unions (2025). This guide is governance guidance, not legal advice. Consult your counsel and primary federal regulator for institution-specific requirements. The AI Banking Institute · AIBankingInstitute.com · v1.1, revised October 2026.